

Хранение секретов вне Git: архитектура и восстановление

1. Принцип

Секреты (пароли, токены, API-ключи) **никогда** не хранятся в отслеживаемых Git файлах и не попадают на GitHub. Они лежат в **едином хранилище вне репозитория**, а конфигурации ссылаются на них по пути.

Единое хранилище:

%USERPROFILE%\
└─ opencode\
 ├─ jira_token.txt
 ├─ confluence_password.txt
 └─ google_api_key.txt

(C:\Users\pchaga\
Jira PAT (MCP atlassian)
пароль Confluence (Basic, MCP atlassian)
ключ провайдера Google

Каталог расположен **вне** `C:\AIS\AI\Prod`, поэтому физически не может попасть в репозиторий `C:\AIS\AI\Prod` даже при ошибке в `.gitignore`.

2. Топология: кто откуда берёт секреты

Секрет	Файл хранилища	Потребитель	Способ подключения
Jira PAT	<code>~/.ais-secrets/opencode/jira_token.txt</code>	MCP atlassian (Jira)	<code>{file:~/.ais-secrets/opencode/jira_token.txt}</code> в обоих <code>opencode.jsonc</code>

Пароль Confluence	<code>~/.ais-secrets/opencode/confluence_password.txt</code>	MCP atlassian (Confluence Basic)	<code>{file:~/.ais-secrets/opencode/confluence_password.txt}</code>
Google API-ключ	<code>~/.ais-secrets/opencode/google_api_key.txt</code>	провайдер google	<code>{file:~/.ais-secrets/opencode/google_api_key.txt}</code>
Пароль/ логин EWS	<code>~/.config/ews-mcp/credentials.env</code>	MCP <code>ews</code>	штатный загрузчик EWS (<code>~/.config/ews-mcp/credentials.env</code>)
Секреты PS-модулей	<code>C:\AIS\AI\Prod\config\.local_secrets.json</code>	PowerShell-модули проекта	<code>scripts\Read-SecretFromConfig.ps1</code>

Подстановка `{file:...}` в конфигурации OpenCode поддерживает относительные пути (от каталога конфига), абсолютные (начинаются с `/`, `~`) — см. документацию OpenCode, раздел Variables → Files.

3. Почему это не ломает работу системы

- 1. **Секреты не удалены** — они перенесены в `~/.ais-secrets` и остаются на диске.
- 2. **Конфиги ссылаются по пути** — при запуске OpenCode подставляет содержимое файла в поле. Для Jira/Confluence/Google работает так же, как раньше (проверено: Jira HTTP 200, Confluence HTTP 200).
- 3. **Файлы только на чтение для конфигов** — потеря/замена не портит сам конфиг, достаточно восстановить файл.
- 4. **Единый чекер** `scripts\Test-Secrets.ps1` заранее сообщает, чего не хватает, и не печатает значения.

4. Восстановление работоспособности

Проверка

```
powershell -NoLogo -File C:\AIS\AI\Prod\scripts\Test-Secrets.ps1 -Online
```

- офлайн: есть ли файлы и не пустые ли они;
- `-Online` : реальные запросы к Jira (`/rest/api/2/myself`) и Confluence (`/rest/api/user/current`).

Если файлов нет

```
powershell -NoLogo -File C:\AIS\AI\Prod\scripts\Test-Secrets.ps1 -Init
```

Создаёт структуру `~/.ais-secrets/opencode` и пустые файлы. Далее впишите значения:

- `jira_token.txt` — PAT Jira (Профиль Jira → Personal Access Tokens);
- `confluence_password.txt` — пароль доменной учётной записи (Basic для Confluence);
- `google_api_key.txt` — ключ Google AI.

Значения можно взять из корпоративного менеджера паролей или из `config\local_secrets.json`. После заполнения — **перезапуск OpenCode** (значения читаются при старте).

Если пароль/токен скомпрометирован

1. Сменить секрет в источнике (Jira/Confluence/Google/EWS).
2. Обновить соответствующий файл в `~/.ais-secrets/opencode` (желательно без BOM и без перевода строки).
3. Перезапустить OpenCode.
4. Проверить: `Test-Secrets.ps1 -Online`.

5. Что было исправлено (инцидент 18.09.2026)

Проблема	Решение
Каталог <code>.config</code> — junction внутри репозитория; глобальный <code>opencode.jsonc</code> отслеживался Git	Секреты вынесены в <code>~/.ais-secrets</code> ; в конфиге — только подстановки <code>{file:...}</code>
Jira PAT, Google API-ключ, EWS-логин/пароль были закоммичены и опубликованы на GitHub	Секреты ротированы; файл <code>credentials.env</code> снят с отслеживания (<code>git rm --cached</code>)
API-ключи в <code>rules/pending-tasks.md</code>	Заменены ссылкой на <code>config\.local_secrets.json</code>
Хук <code>scripts\pre-commit.exe</code> даёт ложные срабатывания на <code>{file:...}</code>	Требуется доработка (проверка подстановок вместо значений)

6. Правила на будущее

- Секреты — только в `~/.ais-secrets` (OpenCode) или `config\.local_secrets.json` (PS-модули); в конфигах — ссылки `{file:...}`.
- Никогда не добавлять в Git то, что под каталогом `.config` содержит значения секретов.
- После любых правок секретов — `Test-Secrets.ps1 -online` и перезапуск OpenCode.
- При потере значений — восстановить из менеджера паролей и повторить проверку.